

Forense de Archivos: Análisis Técnico y Extracción de Información Oculta

Metodologías de investigación aplicadas a la respuesta ante incidentes y OSINT. Descubra las evidencias ocultas en los archivos digitales.



Anatomía de la Evidencia Digital



Dato vs. Metadato

El **dato** es el contenido principal: el "qué" de la información. El **metadato** proporciona el contexto: el "quién", "cuándo" y "dónde".

Ubicación de Metadatos

- **Internos:** Dentro del archivo (EXIF, propiedades)
- **Externos:** Sistema de archivos (MACB en Windows, MFT)

❏ Un atacante puede borrar el contenido, pero rara vez limpia todos los metadatos del sistema.

Estructura EXIF: El Estándar de Metadatos de Imágenes

Exchangeable Image File Format

Estándar basado en **etiquetas (tags)** dentro de archivos JPEG y TIFF que almacena información sobre la captura.

Campo Crítico: GPS

Coordenadas de latitud y longitud que revelan la **localización geográfica precisa** donde se tomó la foto.

Número de Serie

Identificador único de la cámara que permite **correlacionar múltiples imágenes** de un mismo dispositivo.

Miniaturas (Thumbnails)

Persisten en el archivo aunque la imagen principal sea editada, revelando el **contenido original**.

Software de Edición

Indica si se usó Photoshop, GIMP o otro programa, revelando el **sistema operativo de origen**.

Metadatos en Documentos de Ofimática

OLE vs. OOXML

Los formatos antiguos (.doc, .xls) usan **Object Linking and Embedding**, mientras los nuevos (.docx, .xlsx) son contenedores basados en **XML comprimido**.

Propiedades Ocultas Peligrosas

- Autores anteriores y revisores
- Tiempo total de edición
- Impresoras utilizadas
- Rutas de red locales (UNC paths)
- Nombres de usuario del sistema

📄 Filtración de estructura de directorios internos y credenciales de la organización



Firmas de Archivo: Los Magic Bytes

1

Definición

Los primeros bytes de un archivo que **definen su tipo real**, independientemente de la extensión que muestre el sistema.

2

Ejemplo PNG

Hexadecimal: 89 50 4E 47

ASCII: %PNG

3

Ejemplo PDF

Hexadecimal: 25 50 44 46

ASCII: %PDF

4

Ejemplo EXE/DLL

Hexadecimal: 4D 5A

Mark Zbikowski (DOS MZ header)

Uso Forense: Identificación de archivos "disfrazados" que intentan evadir filtros de seguridad cambiando solo la extensión.

Análisis Hexadecimal y Endianness



Visualización en Base 16

Representación de datos binarios en **hexadecimal** para identificar patrones, strings y estructuras ocultas en archivos.

Endianness: Orden de Bytes

Big-endian: El byte más significativo primero (Motorola)

Little-endian: El byte menos significativo primero (Intel x86)

Crítico para interpretar correctamente marcas de tiempo (timestamps) en binarios.

Metadatos como Vector en OSINT



Investigación de Fuentes Abiertas

Análisis de archivos publicados en webs institucionales que revelan infraestructura interna, software utilizado y estructura de directorios.



Localización Geográfica

Identificación precisa de la ubicación de un objetivo a través de coordenadas GPS de una foto "inocente" postzada en redes sociales.



Correlación de Identidades

Cruzar números de serie de cámaras, direcciones MAC y hashes para **identificar múltiples cuentas** de un mismo autor.

Inyecciones Maliciosas en Metadatos



Vector Ofensivo

Inyectar scripts XSS o comandos en campos como `Artist`, `Comment` o `Copyright` de archivos multimedia.



Ejecución del Ataque

El exploit se dispara cuando un **software forense, galería web o visor** procesa y muestra los metadatos sin sanitizar correctamente.



Impacto

Compromiso de sistemas de análisis, exfiltración de credenciales del investigador o distribución de malware disfrazado.

📌 El análisis forense requiere siempre entornos aislados y sanitización de metadatos antes de su procesamiento

Herramientas de Análisis: El Toolstack Básico



file

Consulta la base de datos magic para **determinar el tipo real** de archivo independiente de su extensión.

```
file documento.pdf
```



strings

Extrae secuencias de caracteres imprimibles (mínimo 4 caracteres por defecto) útiles para encontrar **IPs, URLs y rutas** en binarios.

```
strings binario.exe
```



exiftool

La **navaja suiza** para leer, escribir y editar metadatos en más de 300 formatos de archivo.

```
exiftool -a -G foto.jpg
```

Anti-Foreense: Sanitización y Límites



Wiping de Metadatos

Herramientas como **MAT2 en Linux** eliminan rastros antes de la publicación, sobrescribiendo campos de metadatos con valores nulos o aleatorios.

Metadatos Internos

Se eliminan correctamente del contenido del archivo mediante overwriting

Metadatos del Sistema

MFT en Windows, inodos en Linux: **requieren wiping del disco** con herramientas especiales (srm, shred)

Snapshots y Copias

Los sistemas de backup (Shadow Copy en Windows, Time Machine en macOS) conservan versiones históricas



Ocultamiento y Manipulación en Análisis Forense

Esteganografía vs. Ofuscación: Dos Estrategias Diferentes



Esteganografía

Ocultar un mensaje dentro de otro medio para que su **existencia pase completamente desapercibida**. El objetivo es la inconspicuidad total.

- Mensaje dentro de imagen
- Datos en audio
- Textos en documentos



Ofuscación

Transformar un mensaje para que sea **extremadamente difícil de entender**, pero sin ocultar que existe algo que analizar.

- Código minificado
- Base64 anidado
- Strings cifrados

 **Clave forense:** El análisis de entropía es fundamental para detectar la presencia de datos ocultos mediante esteganografía.



Concatenación y Archivos "Pegados"

La Técnica del Pegamento Binario

Consiste en unir un archivo JPG con un ZIP usando comandos como `cat`, `copy /b` o software similar de bajo nivel.

01

Visor de Imágenes

Lee el inicio del archivo (JPEG header) y muestra la imagen

02

Descompresor

Busca el final del archivo (ZIP footer) para encontrar los datos comprimidos

03

Análisis Forense

Identifica "datos sobrantes" (Overlays) después del marcador de fin de archivo (EOF)

Archivos Políglotas: El Mimetismo Digital

Definición

Un archivo que es **válido simultáneamente** para dos o más formatos distintos. Satisface la estructura de múltiples tipos de archivo a la vez.

Técnica de Ataque

Estructuras compartidas que cumplen múltiples firmas de archivo. Un mismo binario puede interpretarse como imagen, documento y ejecutable según el software que lo procese.



Antivirus

Ve un simple GIF sin contenido malicioso



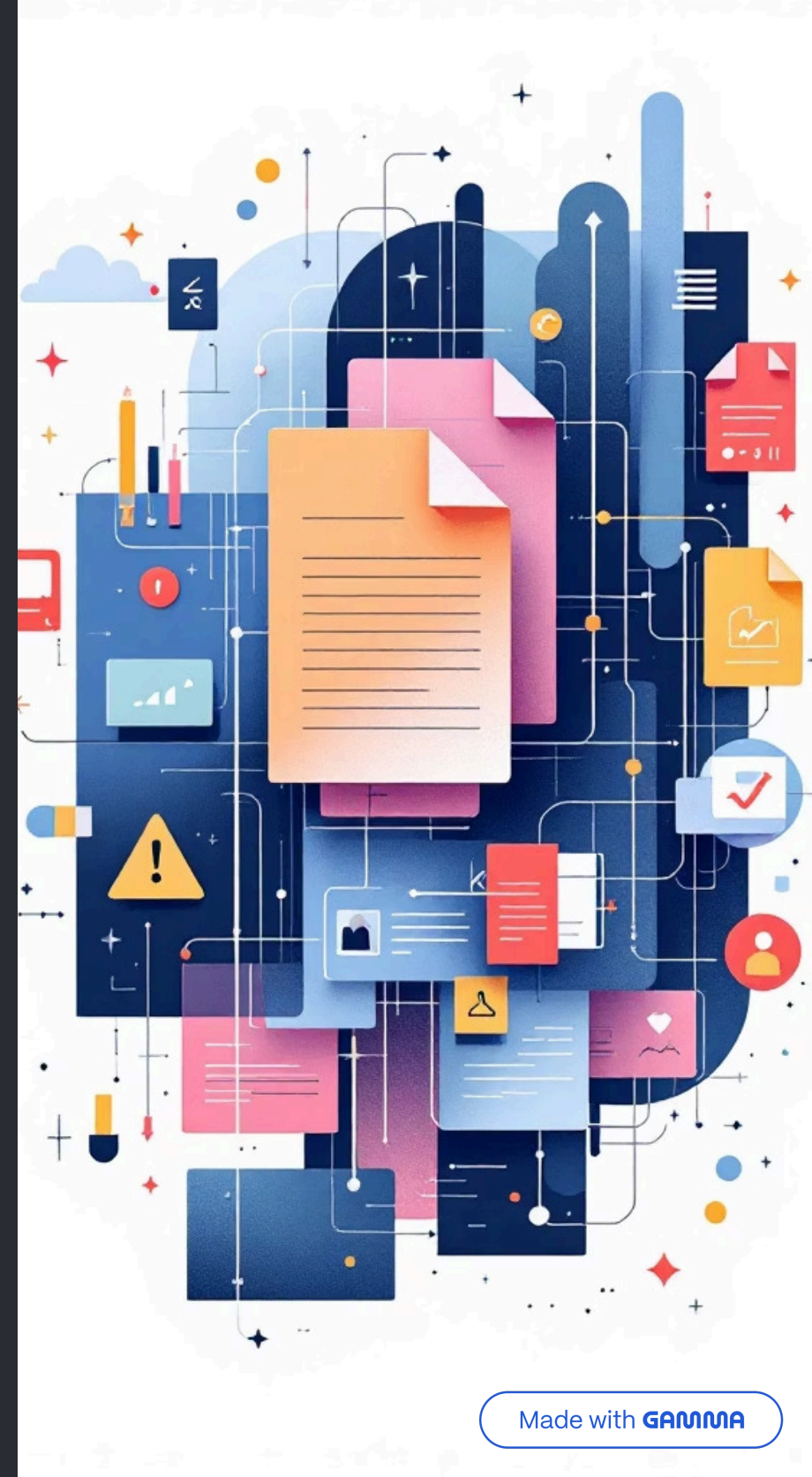
Navegador

Ejecuta el mismo archivo como JavaScript malicioso



Resultado

Infracción de seguridad y ejecución de código arbitrario



Análisis de Entropía de Datos

La Entropía de Shannon revela secretos ocultos

Medida matemática de la aleatoriedad en un conjunto de datos. Cada patrón de entropía revela la naturaleza de los datos.

0-3

Entropía Baja

Texto plano, archivos con patrones repetitivos y muchas repeticiones de ceros

6-8

Entropía Alta

Datos cifrados, comprimidos con algoritmos como ZIP o malware empacado (packed)

Aplicación Forense

Detectar secciones cifradas, inyectadas o datos ocultos dentro de binarios aparentemente normales. Un cambio abrupto de entropía en una sección puede indicar código oculto.



File Carving: Recuperación Basada en Estructuras

Extracción sin Sistema de Archivos

Técnica avanzada que recupera archivos basándose únicamente en sus estructuras internas (Magic Bytes) sin depender del sistema de archivos tradicional.

Escenarios de Uso

- Discos formateados recientemente
- Archivos borrados con shred
- Slack Space no asignado
- Mareas de memoria

Herramientas Clave

- foremost para recuperación automatizada
- scalpel para análisis rápido
- photorec especializado en multimedia

Archivos Office OLE: Sistemas de Archivos en Miniatura

Compound Document File Format

Formato legado de Microsoft Office que funciona como un verdadero sistema de archivos dentro de un único archivo. Utilizado en **.doc**, **.xls**, **.ppt** y otros formatos antiguos.



Streams de Texto

Contienen el contenido principal del documento



Streams de Imágenes

Gráficos, fotos y elementos visuales embebidos



Streams de Macros

Módulos VBA ejecutables: el vector de ataque más peligroso

Análisis Profesional

Uso de [oledump.py](#) para listar todos los streams e identificar el rastro oculto de código VBA malicioso.

Macros VBA: El Código que Se Ejecuta en Silencio

Triggers de Ejecución Automática

Funciones especiales que se activan sin interacción del usuario al abrir el documento.

Auto_Open

Macro ejecutable específico de Excel que se activa cuando se carga la hoja

Document_Open

Macro de Word que corre al cargar cualquier documento tipo .doc

Detecta código ofuscado que utiliza `Char()`, variables aleatorias y codificación base64 para ocultar la descarga de un payload.

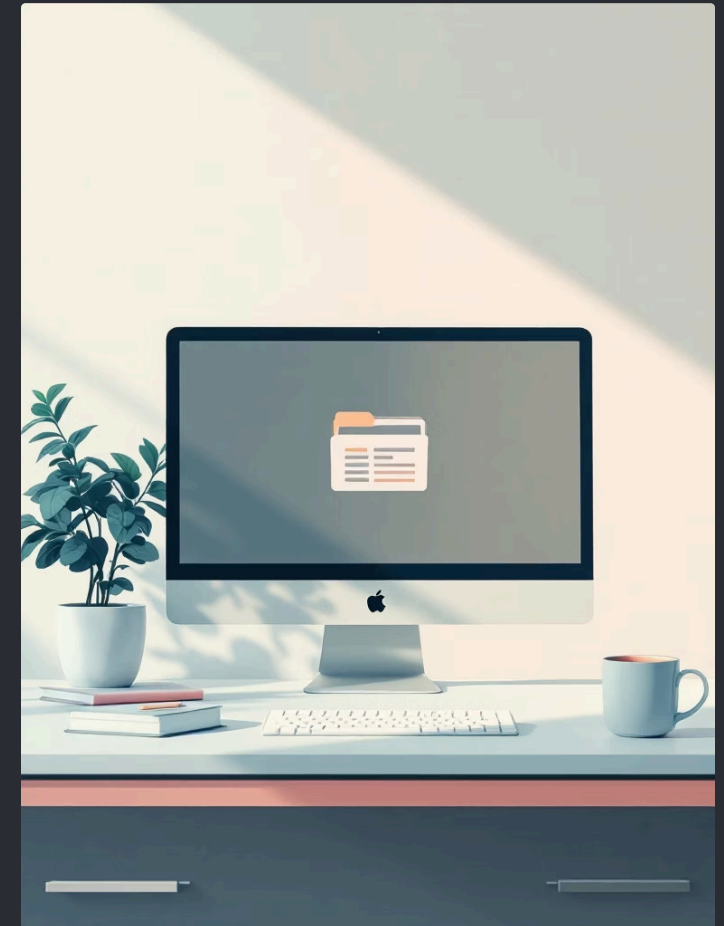
📌 **Atención:** El P-Code (código pre-compilado) puede diferir del código fuente visible, requiriendo descompilación para análisis completo.

Archivos LNK: El Rastro Olvidado

Metadatos Reveladores

Los accesos directos de Windows (.lnk) contienen información sorprendente sobre el sistema y el momento exacto de su creación.

- Dirección MAC del equipo de origen
- Ruta completa del archivo original
- Fechas de creación del sistema remoto
- Identificadores de volumen



Uso Malicioso

Archivos LNK manipulados que ejecutan comandos de PowerShell en segundo plano. La víctima ve un simple acceso directo pero se lanza una shell en background.

Toolstack II: Arsenal de Análisis Estático



binwalk

Escanea archivos en busca de firmas embebidas y extrae automáticamente datos ocultos.



steghide / stegsolve

Herramientas especializadas para análisis LSB y extracción de datos de imágenes.



CyberChef

"El lavadero de datos": decodifica base64, hexadecimal y desofusca scripts interactivamente.

Análisis PE (Portable Executable)

Estructura de archivos .exe y .dll en Windows. Secciones como **.text** (código ejecutable), **.data** (variables) y **.rsrc** (recursos) requieren investigación.

IAT (Import Address Table)

Lista de funciones que el programa solicita a Windows. Detecta comportamiento sospechoso: `URLDownloadToFile` en un bloc de notas es claramente anómalo.

Artefactos y Persistencia en Forense de Sistema



Evidencia de Ejecución en Windows



Principio de Conservación

Windows registra casi todo lo que ejecuta el usuario o el malware para optimizar el rendimiento del sistema



Valor Forense

Prueba tangible de que un archivo estuvo presente y fue abierto, incluso tras su eliminación física del disco

Esta persistencia inherente constituye la base fundamental para reconstruir la cronología de eventos en una investigación digital.

Archivos Prefetch (.pf)

Aceleración Inteligente

Sistema diseñado para acelerar el inicio de aplicaciones mediante la pre-carga de datos frecuentemente utilizados.

Datos Contenidos

- Nombre del ejecutable y ruta completa
- Contador de ejecuciones
- Timestamp de las últimas 8 ejecuciones

Ubicación

C:\Windows\Prefetch - Accesible con privilegios estándar de usuario



Jump Lists y Documentos Recientes

Jump Lists

Menus contextuales emergentes al hacer clic derecho en iconos de la barra de tareas

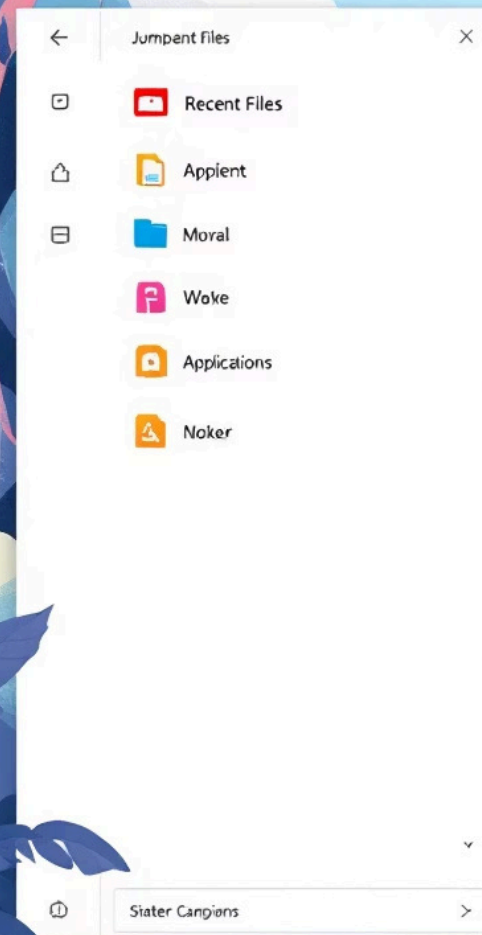
Evidencia Revelada

Archivos específicos abiertos con cada aplicación, fechas exactas y orden de acceso

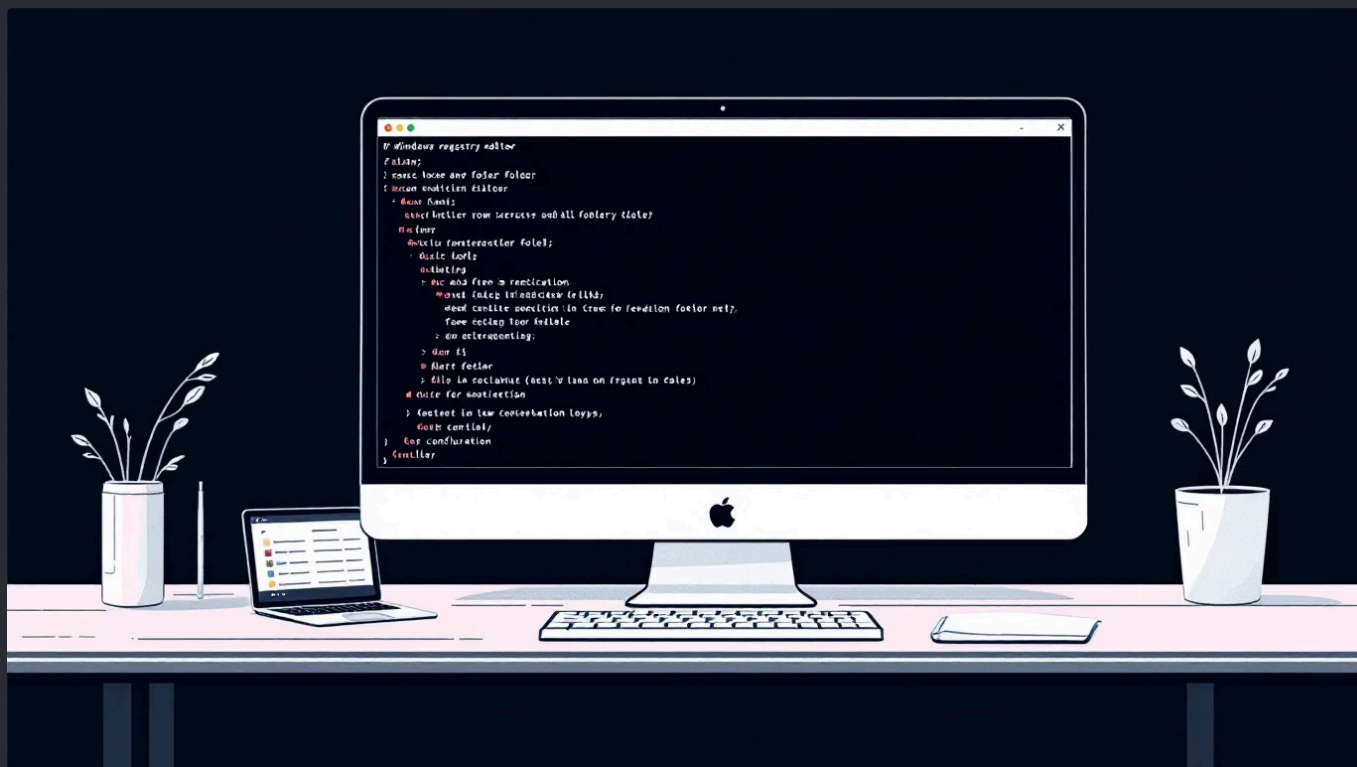
Persistencia Robusta

Mantenidos disponible incluso tras eliminación del archivo original del sistema

Estos artefactos revelan patrones de comportamiento y relaciones entre ejecutables y documentos que resultan cruciales para establecer la cronología de eventos.



Shellbags: Registro de Navegación



Concepto Técnico

Claves de registro que almacenan preferencias de visualización de carpetas: tamaño de iconos, posición en pantalla, modo de vista

Valor Investigativo

Permiten reconstruir la estructura de carpetas de discos desmontados o directorios eliminados por acciones maliciosas

Persistencia Notable

Mantienen memoria de ubicaciones de archivo durante meses, incluso tras desmontaje del volumen

Alternate Data Streams (ADS)

01

Característica NTFS

Permite asociar múltiples flujos de datos a un único nombre de archivo mediante el sistema de archivos NTFS

02

Uso Malicioso Común

Esconder ejecutables completos en flujos ocultos de archivos inocuos (ej: `archivo.txt:malware.exe`)

03

Ocultación Efectiva

Windows reporta el mismo tamaño del archivo principal. Requiere comandos específicos (`dir /r`) para detección

04

Detección Profesional

Herramientas forenses avanzadas identifican anomalías mediante análisis de estructura NTFS completa

Run Keys Fundamentales

Software\Microsoft\Windows\CurrentVersion\Run

Software\Microsoft\Windows\CurrentVersion\Run

Nombres que imitan procesos del sistema

Localizaciones inusuales en AppData

Verificación criptográfica de integridad

Tareas Programadas: El Método Favorito

Ubicación Forense

Archivos XML en

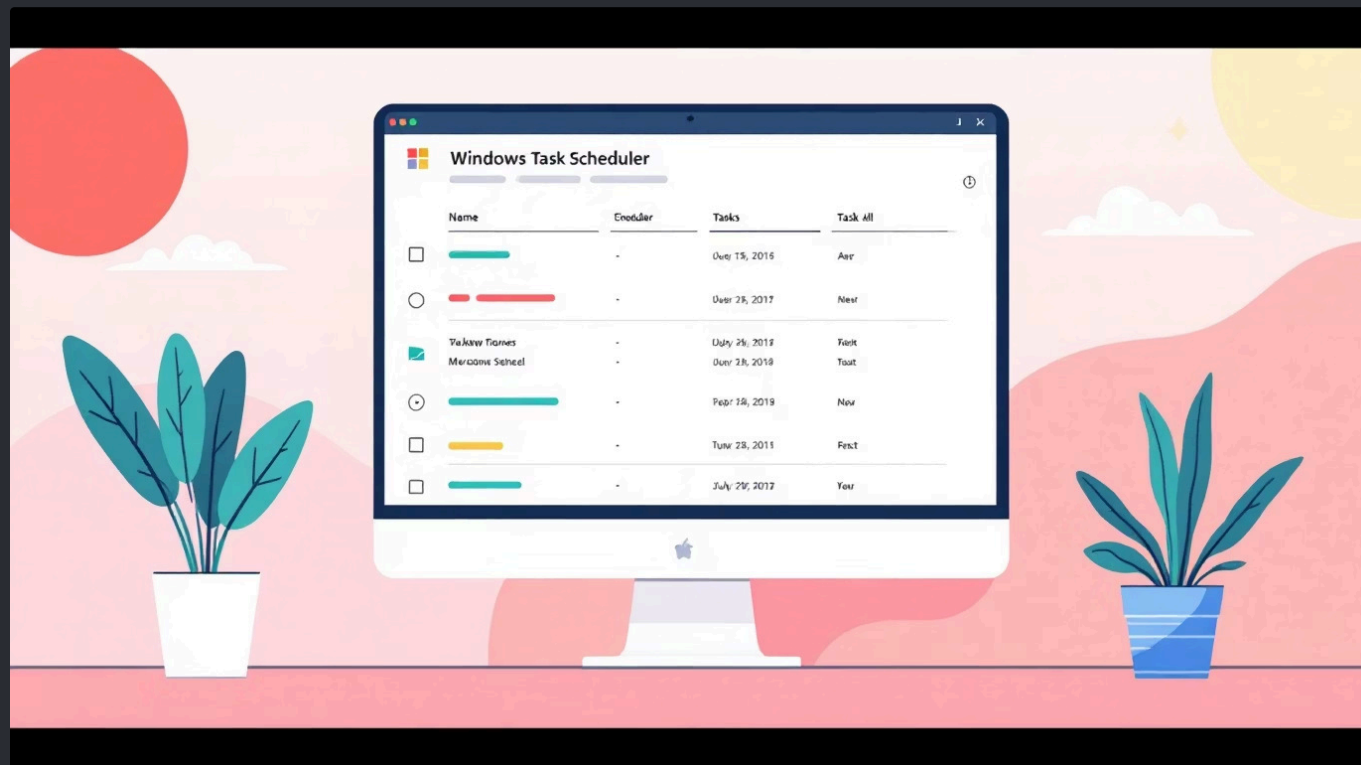
C:\Windows\System32\Tasks - Formato legible que facilita análisis manual

Información Crítica

- Fecha y hora de creación de la tarea
- Usuario que inició la programación
- Acción específica (comando ejecutado)
- Frecuencia y condiciones de disparo

Preferencia Maliciosa

Método favorecido para mantener acceso persistente tras reinicio del sistema



Metodología de Análisis: Triage y Timelines



Las Cuatro Fechas Críticas

Modify, Access, Create, Birth permiten construir narrativa completa: **entrada inicial**, **movimiento lateral**, **exfiltración de datos**

Consideraciones Éticas y Profesionales

La Evidencia Habla, El Perito Interpreta

Los artefactos son objetivos, pero su contextualización requiere juicio profesional fundamentado

Análisis es Base para Prevención

Cada incidente resuelto aporta información para hardening de sistemas y mejora de postura de seguridad

"El análisis forense meticuloso constituye la fundación sobre la que se construye la respuesta ante incidentes efectiva y la prevención de futuros ataques."